

Lab 12: Secure a Finance Agent for PDPA and Human Oversight

Course: Microsoft Copilot for Finance (C057)

Mapping: K3 · A4 · A5

Suggested time: 60 minutes

Objective: Apply PDPA, data-classification, security and oversight controls, then decide whether the agent may be published.

Scenario

The finance agent is proposed for wider deployment. Before it is released, it must pass a PDPA review, a security review and an oversight review.

Files

- `northstar-agent-security-starter.xlsx` - learner working file
- `northstar-agent-security-solution.xlsx` - completed formulas, controls and charts for review
- `evidence-checklist.md` - submission and verification checklist
- `adversarial-prompts.json` - synthetic security tests
- `pdpa-checklist.md` - PDPA obligations checklist
- `../TENANT-RESOURCES.md` - sign-in accounts, site, environment and agent links

Before you begin

- Use only the supplied synthetic data.
- Do not enter live customer, payroll, account, credential or confidential data.
- If the required Microsoft feature is not enabled in your tenant, complete the workbook-based simulation and record the limitation.
- Keep facts, assumptions, AI suggestions and reviewer decisions visibly separate.

Detailed procedure

Step 1: Inventory the agent: purpose, owner, users, knowledge sources, tools and connectors.

- Complete the Agent Inventory sheet for the agent you are reviewing.
- You cannot govern an agent that has no recorded owner, purpose or scope.

Record the evidence for Step 1 in the checklist before continuing.

Step 2: Complete the PDPA review: purpose, consent basis, minimisation, retention and the DPO contact.

- Work through the PDPA Review sheet obligation by obligation.
- Purpose limitation is the one most often failed: data collected for billing is not automatically available for AI.

Record the evidence for Step 2 in the checklist before continuing.

Step 3: Classify every data source the agent can reach and confirm no restricted data is in scope.

- Classify every data source the agent can reach on the Data Classification sheet.
- Restricted data, meaning payroll, NRIC, bank details and credit files, must never be in scope for any AI prompt.

Record the evidence for Step 3 in the checklist before continuing.

Step 4: Check the authentication setting and justify it; internal finance content must never be no-auth.

- Open the agent's Settings and check the authentication mode.
- Authenticate with Microsoft is correct for internal finance content.
- No authentication publishes a demo website reachable by anyone with the link. Justify your setting in writing.

Record the evidence for Step 4 in the checklist before continuing.

Step 5: Review the knowledge scope and test whether the agent can reach content the asker should not see.

- Review the knowledge scope. Test whether the agent surfaces anything the asking user should not see.
- The narrowest scope that answers the question is the right one.

Record the evidence for Step 5 in the checklist before continuing.

Step 6: Run the supplied adversarial prompts, including prompt injection and approval-bypass attempts.

- Run the adversarial prompts from adversarial-prompts.json against the training agent only.
- Use synthetic data. Never run these against production or against real customer records.
- Record the actual response for each, not just pass or fail.

Record the evidence for Step 6 in the checklist before continuing.

Step 7: Record which controls are structural and which are only procedural, and rank them.

- Complete the Control Ranking sheet.
- Separate structural controls the model cannot reach from procedural ones written into a prompt, and from conventions such as a self-declared name.

Record the evidence for Step 7 in the checklist before continuing.

Step 8: Review the approval gate default and confirm inaction fails safe.

- Check the approval gate default on any connected workflow.
- Confirm that inaction results in rejection rather than approval.

Record the evidence for Step 8 in the checklist before continuing.

Step 9: Set out the oversight model and confirm the reviewer has evidence, time and a real ability to reject.

- Complete the Human Oversight sheet.
- Ask honestly whether the reviewer has the evidence, the time and a realistic ability to say no. If not, the oversight is decorative.

Record the evidence for Step 9 in the checklist before continuing.

Step 10: Issue a publish, remediate or reject recommendation with residual risk and a named owner.

- Issue your recommendation on the Publish Decision sheet.
- Name the highest residual risk, who accepts it, the review date and the rollback plan.
- A recommendation without a named risk acceptor is not a decision.

Record the evidence for Step 10 in the checklist before continuing.

Prompt quality pattern

Role: You are assisting a finance professional. Task: analyse only the named workbook table. Data boundary: do not use external or unstated facts. Controls: reconcile totals, identify missing evidence, and label assumptions. Output: return a concise table of finding, evidence, confidence, reviewer action and source cell or table.

Acceptance criteria

- ☐ Every high risk has a preventive and a detective control with test evidence; the PDPA review is complete with a named DPO; no restricted data is in scope; adversarial tests are evidenced; the recommendation names a residual risk and an accountable owner.
- ☐ All generated claims have been checked against the workbook or approved knowledge.
- ☐ No live credentials, personal data or confidential business data appear in the evidence.

- ☐ A human reviewer and approval status are recorded.

Deliverable

A completed security and PDPA review with adversarial test evidence and a publish decision.

Reflection

1. What did the AI accelerate?
2. What still required finance judgement?
3. Which control prevented the most serious failure?
4. What evidence is needed before this design can scale?

© 2026 Tertiary Infotech Academy Pte Ltd · UEN 201200696W